後量子密碼遷移自動化盤點框架操作說明書

1. 系統簡介

本工具是一個跨語言（Python/Java）的靜態程式碼分析掃描器，專門用於協助企業進行後量子密碼學（PQC）遷移。它能自動識別程式碼中的傳統加密演算法、量子脆弱資產、硬編碼機密以及不安全的參數配置，並生成標準化的 CBOM（密碼學物料清單）與視覺化風險儀表板。

核心功能

- 量子脆弱性盤點：識別 RSA、ECC 等需遷移的演算法。
- PQC 正面識別：偵測已導入的 NIST 標準演算法（Kyber, Dilithium）。
- 機密安全檢查：掃描硬編碼的金鑰、密碼、AWS 憑證與 API Token。
- 進階參數驗證：檢查 ECC 曲線強度、PBKDF2 迭代次數、Salt 長度等。
- 視覺化報告：自動生成包含風險分佈圓餅圖的 HTML 儀表板。

2. 環境需求與安裝

2.1 系統需求

- 作業系統：Windows / macOS / Linux
- 程式語言：Python 3.9 或更高版本
- 瀏覽器：Chrome / Edge / Firefox（用於查看 HTML 報告）

2.2 安裝步驟

1. 建立專案目錄 將 pqc_ast_scanner.py 放入您的專案資料夾中，例如 Project-PQC。

2. 建立虛擬環境（建議）為了避免套件衝突，建議使用虛擬環境。在終端機（Terminal/PowerShell）執行：

建立虛擬環境

```
python -m venv venv

# 啟動虛擬環境（Windows PowerShell）
.\venv\Scripts\Activate.ps1

# 啟動虛擬環境（macOS/Linux）
source venv/bin/activate
```

2. 安裝依賴套件

本工具依賴以下 Python 函式庫，請執行安裝指令：

```
pip install javalang pycparser pandas plotly
```

套件名稱	用途
javalang	解析 Java 原始碼 AST
pycparser	解析 C/C++ 原始碼 AST（預留介面）
pandas	數據處理與統計
plotly	生成互動式 HTML 圖表

3. 使用方法

本掃描器支援專案掃描模式。

3.1 掃描指定檔案或目錄

若要掃描您實際的專案代碼，請在指令後方加上路徑。

掃描單一檔案：

```
python pqc_ast_scanner.py C:\Projects\MyApp\auth.py
```

掃描整個目錄（遞迴掃描）：

```
python pqc_ast_scanner.py C:\Projects\MyApp\src
```

（系統會自動尋找該目錄下所有的 .py 和 .java 檔案進行分析。）

4. 產出報告說明

掃描完成後，工具會在執行目錄下生成兩份關鍵文件：

4.1 PQC_CBOM_Inventory.json（密碼學物料清單）

這是符合 CycloneDX 結構的 JSON 檔案，適合機器讀取或與其他資安工具整合。

- 內容包含：
  - crypto-assets：所有偵測到的加密資產列表。
  - pqc_status：資產的量子安全狀態（如 VULNERABLE (QUANTUM), PQC_READY）。
  - occurrences：檔案路徑與行號。

4.2 PQC_Risk_Dashboard.html（風險儀表板）

這是一份互動式的 HTML 報告，適合人類閱讀與展示。

- 風險分佈圖（Pie Chart）：使用顏色區分風險等級。
  - 🔴 紅色（Critical）：硬編碼機密、弱雜湊（MD5）。
  - 🟠 橙色（High）：實作錯誤（Salt 過短、ECC 曲線弱）。
  - 🔵 藍色（PQC Target）：需遷移的傳統公鑰（RSA, ECC）。
  - 🟢 綠色（Secure）：已遷移的 PQC 演算法（Kyber, Dilithium）或安全 AES。
- 詳細清單表格：列出每一個發現的代碼片段、位置與修復建議。

5. 常見問題排除

Q1: 出現 ModuleNotFoundError: No module named '...'

- 原因：未安裝依賴套件或未進入虛擬環境。
- 解法：確認終端機前方有 (venv) 提示，並重新執行 pip install javalang pycparser pandas plotly。

Q2: 掃描結果為 0，但我確定代碼有問題

- 原因：可能是路徑錯誤，或是目標檔案是空的。
- 解法：請確認您輸入的路徑是絕對路徑或正確的相對路徑。若是掃描測試檔，請確認測試檔內已寫入包含漏洞的程式碼。

Q3: PowerShell 顯示「無法載入檔案...因為這個系統上已停用指令碼執行」

- 解法：這是 Windows 權限問題。請以管理員身分執行 PowerShell 並輸入： Set-ExecutionPolicy RemoteSigned -Scope Process 然後再嘗試啟動虛擬環境。

6. 規則庫維護

若需新增或修改掃描規則，請直接編輯 pqc_ast_scanner.py 中的 PQC_KNOWLEDGE_BASE 字典。

- Type: 漏洞類型名稱。
- Severity: 風險等級 (Critical, High, PQC Target, Secure)。
- Message/Fix: 顯示在報告中的說明與建議。